

XII.DEMONSTRATE CYBER EVASION TECHNIQUES

Aim:

To learn cyber evasion techniques and put them to the test against two IDS.

Procedure:

1. Deploy the target machine and register on the IDS monitoring system.
2. Perform reconnaissance using tools like nmap and observe IDS alerts.
3. Apply evasion techniques (change user-agent, stealth scan) and analyze detection differences.
4. Exploit discovered vulnerabilities (e.g., Grafana) to gain initial access and escalate privileges.
5. Establish persistence using Docker/backdoor and monitor IDS responses.

Tasks:

Task 1:Introduction

Deploy the target machine and create an account and log into the system at http://MACHINE_IP:8000, in preparation for future tasks.

No answer needed

✓ Correct Answer



Task 2:Intrusion detection basics

What IDS detection methodology relies on rule sets?

signature-based detection

✓ Correct Answer

Task 3: Network-based IDS(NIDS)

What widely implemented protocol has an adverse effect on the reliability of NIDS?

TLS

✓ Correct Answer



Experiment by running tools against the target and viewing the resultant alerts. Is there any unexpected activity?

No answer needed

✓ Correct Answer



Task 4: Reconnaissance and Evasion basics

What scale is used to measure alert severity in Suricata? (*-*)

1-3

✓ Correct Answer



How many services is nmap able to fully recognise when the service scan (-sV) is performed?

3

✓ Correct Answer



Task 5: Further Reconnaissance Evasion

Nikto, should find an interesting path when the first scan is performed, what is it called?

/login

✓ Correct Answer

What value is used to toggle denial of service vectors when using scan tuning (-T) in nikto?

6

✓ Correct Answer



Which flags are used to modify the request spacing in nikto? Use commas to separate the flags in your answer.

6,A,B

✓ Correct Answer



Task 6: Open-source Intelligence

What version of Grafana is the server running?

8.2.5

✓ Correct Answer



What is the ID of the severe CVE that affects this version of Grafana?

CVE-2021-43798

✓ Correct Answer



If this server was publicly available, What site might have information on its services already?

shodan

✓ Correct Answer

How would we search the site "example.com" for pdf files, using advanced Google search tags?

site:example.com filetype:pdf

✓ Correct Answer

Task 7: Rulesets

What is the password of the grafana-admin account?

GraphingTheWorld32

✓ Correct Answer



Is it possible to gain direct access to the server now that the grafana-admin password is known?
(yay/nay)

yay

✓ Correct Answer



Are any of the attached IDS able to detect the attack if the file /etc/shadow is requested via the exploit, if so what IDS detected it?

Suricata

✓ Correct Answer



Task 8: Host Based IDS(HIDS)

What category does Wazuh place HTTP 400 error codes in?

web

✓ Correct Answer



Play around with some post-exploitation tools and commands and make note of what activity is detected by Wazuh; compare it to the activity that's detected by Suricata.

No answer needed

✓ Correct Answer

Task 9: Privilege Escalation Recon

What tool does linPEAS detect as having a potential escalation vector?

docker

✓ Correct Answer



Is an alert triggered by Wazuh when linPEAS is added to the system, if so what its severity?

5

✓ Correct Answer



Task 10: Performing Privilege Escalation

Perform the privilege escalation and grab the flag in /root/

{SNEAK_ATTACK_CRITICAL}

✓ Correct Answer

Task 11: Establishing Persistence

Abuse docker to establish a backdoor on the host system

No answer needed

✓ Correct Answer

Task 12: Conclusion

Read the above

No answer needed

✓ Correct Answer

Result:

Hence learned cyber evasion techniques and put them to the test against two IDS.

